

OAuth Token Replay Abuse response

Identity / SaaS · **Critical** severity · SOC IR Playbook

Incident type	Identity Compromise - Token Abuse
Severity	Critical
Priority	Critical
Detection sources	SIEM, Cloud Audit Logs, API Gateway Logs, Identity Provider Logs (e.g., Okta, Azure AD), CASB, Threat Intel Feeds

Scenario

An attacker obtains a valid OAuth access token (e.g., via phishing, token theft or insecure storage) and reuses it to access APIs, web applications or cloud services as the victim - bypassing MFA and other login protections since the token is already trusted.

MITRE ATT&CK

T1078.004, T1528, T1550.003

Preparation

Enforce token expiration and rotation Set short token lifetimes and enforce refresh token limits Monitor token usage patterns Use identity protection or SIEM to alert on abnormal API access using tokens Tie tokens to device/session Bind issued tokens to IP/device fingerprints where possible Implement Conditional Access Check context (e.g., location, app, risk score) before allowing token-based access Log all token issuance and usage From identity providers and application gateways

Detection & Analysis

Alert triggered Abnormal token usage such as reuse from new location or impossible travel behaviour Investigate token use patterns Check endpoints accessed, time of use, associated IP and user-agent metadata Correlate with token issuance Determine when and where the token was first created and if it aligns with the legitimate user Assess exposure risk Determine whether data access, privilege escalation or account actions occurred

Containment

Revoke active tokens Invalidate both access and refresh tokens via IdP or app settings Block source IPs If replay originated from known malicious infrastructure or unusual regions Suspend affected user accounts Temporarily disable to prevent continued exploitation during investigation Alert user and security team Notify of the potential compromise and suspend external access if needed

Eradication

Rotate credentials and secrets Especially for third-party applications or APIs tied to the same account Audit and remove malicious app consents Check for OAuth apps granted by the user that may be controlled by the attacker Tighten app permission scopes Restrict apps to only request minimum access necessary (principle of least privilege) Apply security controls to apps Require app verification or tenant-level consent approval for future apps

Recovery

Reinstate user account After confirming user identity and account integrity Monitor token activity post-recovery Ensure new tokens are being used only from trusted locations and devices Revalidate app and API access Confirm legitimate session behaviour across critical services Resume operations After confirming full containment and credential hygiene

Lessons Learned & Reporting

Perform root cause analysis Determine how the token was obtained (e.g., phishing, local storage exposure, browser extension) Update token issuance policies Reduce token lifetimes, enforce refresh limits and bind to

context Improve detections Add token replay pattern signatures to SIEM and identity protection platforms Educate users and dev teams On secure storage and handling of OAuth tokens (especially in browser-based apps) Report if required Especially if sensitive data was accessed (e.g., under GDPR, HIPAA or PDPA)

Tools typically involved

Identity Providers (e.g., Okta, Azure AD, Google Workspace); SIEM (e.g., Sentinel, Splunk, QRadar); CASB (e.g., Netskope, Microsoft Defender for Cloud Apps); API Security Tools (e.g., Salt Security, Noname, Imperva API Security); Cloud Audit Logs (e.g., AWS CloudTrail, Azure Sign-in logs, GCP Admin Activity); User Behaviour Analytics (e.g., Exabeam, Securonix)

Success metrics (SLA targets)

Detection Time <10 minutes from abnormal token use
Token Revocation Time <15 minutes after confirmation
Account Risk Mitigation Time <1 hour
OAuth App Audit Completion 100% of consents reviewed within 24 hours
Post-Incident Monitoring Period Minimum 7 days with enhanced visibility